CYBERSECURITY AVANZATA · LEZIONI 1-8

Simulazione della verifica di cybersecurity avanzata

Stessa struttura e stessa difficoltà della verifica vera, con un caso e domande diversi. Fai la prova in 75 minuti con la sola calcolatrice, poi correggiti con le soluzioni in fondo.

Nome e cognome | Classe | Data

Il caso. La pizzeria d'asporto Forno Blu (inventata) riceve ordini da un sito scritto in Java, sul dominio `fornoblu.example`, con un'area clienti e recensioni. Gli esercizi da 3 a 9 si riferiscono a questo caso.

1. Scelta multipla

18 punti · 3 per domanda

Segna una sola risposta per ogni domanda.

a) Un CVE è…

- O un punteggio di gravità da 0 a 10
- O un identificativo unico pubblico di una vulnerabilità nota
- O un antivirus
- O una patch di sicurezza

b) Quale funzione è adatta a conservare le password?

- O MD5
- O SHA-256 semplice
- O Argon2id o PBKDF2 con salt
- O Base64

c) Il browser si fida del certificato di un sito perché…

- O il sito lo dichiara valido
- O è firmato, attraverso una catena, da un'autorità di certificazione che il browser conosce
- O è cifrato con la password dell'utente
- O usa la porta 443

d) In OAuth 2.0 l'app che chiede "Accedi con…" riceve…

- O la password dell'utente
- O un token con permessi limitati
- O la chiave privata del provider
- O il cookie del provider

e) DKIM serve a…

- O firmare la mail per provare che viene dal dominio e non è stata alterata
- O cifrare la mail
- O bloccare lo spam in arrivo
- O elencare i server di posta del dominio

f) In una cattura vedi centinaia di SYN verso porte diverse dello stesso server e quasi nessun SYN-ACK. È probabilmente…

- O una videochiamata
- O una scansione delle porte
- O un download
- O un aggiornamento DNS

2. Vero o falso

12 punti · 1,5 per frase

V ☐ **F** ☐ Una Content Security Policy ben fatta può bloccare gli script inseriti con un XSS.
V ☐ **F** ☐ Il salt va tenuto segreto come la password.
V ☐ **F** ☐ TLS 1.3 cifra anche il certificato del server durante l'handshake.
V ☐ **F** ☐ Una passkey può essere rubata con una pagina di phishing identica al sito vero.
V ☐ **F** ☐ Un SPF che finisce con `-all` dice di rifiutare le mail dai server non elencati.
V ☐ **F** ☐ Con una VPN commerciale il fornitore della VPN può vedere i nomi dei siti che visiti.
V ☐ **F** ☐ In un'indagine forense l'analisi si fa sulla copia, non sull'originale.
V ☐ **F** ☐ Se l'ultimo accesso di un file non è cambiato, è dimostrato che nessuno lo ha aperto.

3. Leggere un avviso di sicurezza

10 punti

Un cliente ha scoperto che, cambiando il numero nell'indirizzo `/ordini/1532`, vede gli ordini degli altri clienti. Il vettore assegnato è `CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N`, punteggio 6,5.

a) Spiega `PR:L`, `UI:N` e `C:H/I:N/A:N`. *(3 punti)* b) In quale fascia di gravità cade 6,5? *(2 punti)*
c) Come si chiama questa categoria di falla nell'OWASP Top 10, e come si corregge nel codice? *(2 punti)*
d) Il cliente vorrebbe pubblicare subito la scoperta sui social. Che cosa gli consigli e perché? *(3 punti)*

4. XSS e CSRF nel codice

12 punti

```
// 1) recensioni: il testo viene salvato nel database e mostrato a tutti
risposta.write("<li>" + recensione.getTesto() + "</li>");

// 2) POST /cambia-email   con il campo email   (vale il cookie di sessione, nessun altro controllo)
```

a) Un utente scrive una recensione con dentro `<script>`. Che tipo di XSS è e chi colpisce? *(3 punti)*
b) Correggi la riga 2 e mostra come diventa `"Ottima" & <i>veloce</i>`. *(3 punti)*
c) Che cosa fa l'header `Content-Security-Policy: default-src 'self'; object-src 'none'`? *(2 punti)*
d) Anche se è una POST, il cambio email è vulnerabile a CSRF. Spiega come e indica due difese. *(4 punti)*

5. Le password dei clienti

12 punti

Le password sono salvate come `SHA-256(password)` senza salt. L'attaccante prova $\mathbf{10^{10}}$ hash al secondo. I clienti usano solo **lettere minuscole e cifre** (36 simboli), lunghe **8 caratteri**.

a) Quante sono le combinazioni? *(2 punti)* b) Quanto tempo serve, nel caso peggiore, in minuti? *(3 punti)*
c) Con PBKDF2 a 600 000 iterazioni, quanto tempo serve in anni? (1 anno ≈ $3{,}16 \times 10^7$ s) *(3 punti)*
d) Che cos'è il credential stuffing e perché è pericoloso anche se il sito della pizzeria non ha falle? *(2 punti)* e) Come può il sito controllare se una nuova password compare in fughe di dati note, senza inviarla a nessuno? *(2 punti)*

6. Il token dell'API

10 punti

```
{"alg":"HS256","typ":"JWT"} . {"sub":"cliente31","ruolo":"cliente","exp":1700000000} . (firma)
```

a) `exp` vale 1700000000, cioè novembre 2023. Che cosa risponde il server a `GET /api/ordini` e perché? *(2 punti)*
b) Un attaccante cambia l'header in `{"alg":"none"}`, cambia il ruolo in `"admin"` e toglie la firma. Che cosa deve fare un server scritto bene? *(3 punti)*
c) Dove si conserva il segreto di firma HS256, e perché non va scritto nel codice? *(2 punti)*
d) Perché per confrontare le firme si usa `MessageDigest.isEqual` invece di `equals`? *(3 punti)*

7. Chi può fingersi la pizzeria?

8 punti

Dominio	SPF	DMARC in _dmarc.dominio
fornoblu.example	`v=spf1 include:_spf.posta.example -all`	`v=DMARC1; p=none; rua=mailto:dmarc@fornoblu.example`
consegne-veloci.example	nessun record	nessun record

a) Dai a ciascun dominio il giudizio protetto, in osservazione o scoperto, e motiva. *(3 punti)* b) Che cosa deve fare la pizzeria per passare a "protetto", e perché non subito? *(3 punti)*
c) Una mail arriva da `fornobIu.example` (con la I maiuscola al posto della l). Perché DMARC non aiuta e che cosa aiuta? *(2 punti)*

8. Che cosa passa sulla rete

10 punti

a) Abbina ogni filtro a ciò che mostra: `dns`, `tcp.port == 443`, `http.request.method == "POST"`; 1) l'invio di moduli in HTTP in chiaro, 2) domande e risposte sui nomi, 3) il traffico HTTPS su TCP. *(3 punti)*
b) Il SYN e il SYN-ACK verso il server sono distanti 38 ms. Che cosa misura, più o meno, questo tempo? *(2 punti)*
c) Con il sito in HTTPS, che cosa vede il gestore della Wi-Fi di un cliente che ordina, e che cosa no? *(3 punti)*
d) Il titolare vuole catturare il traffico dei clienti sulla Wi-Fi gratuita "per statistiche". Che cosa gli rispondi? *(2 punti)*

9. Dopo l'incidente **8 punti · 2 per risposta**

a) Metti in ordine di volatilità: disco, RAM, backup, log su un server remoto.

b) Che cos'è un write blocker e a che cosa serve?

c) Nel registro eventi di Sistema trovi un 6006 alle 23:10 e un 6005 alle 23:12. Che cosa è successo?

d) Perché una timeline costruita da più fonti indipendenti è più solida di una sola fonte?

Punti: _____ / 100 **Voto: _____**

Soluzioni

1. Scelta multipla

a) **identificativo unico pubblico** (il punteggio è il CVSS). b) **Argon2id o PBKDF2 con salt**. c) **firmato da un'autorità che il browser conosce**. d) **un token con permessi limitati**. e) **firmare la mail**. f) **una scansione delle porte**.

2. Vero o falso

1 **V** (blocca gli script inline e da altri domini). 2 **F** (sta in chiaro accanto all'hash). 3 **V**. 4 **F** (è legata al dominio vero). 5 **V**. 6 **V** (la VPN sposta la fiducia). 7 **V**. 8 **F** (Windows spesso non aggiorna l'ultimo accesso: un dato assente non prova nulla).

3. Avviso di sicurezza

a) **PR:L** basta un account normale; **UI:N** non serve nessuna azione della vittima; **C:H/I:N/A:N** si leggono dati riservati, ma non si modificano né si blocca il servizio. b) **Media** (4,0–6,9). c) **Broken Access Control** (riferimento diretto insicuro, IDOR): il server deve controllare che l'ordine appartenga all'utente della sessione, non solo che l'utente sia collegato. d) **Divulgazione coordinata**: avvisare la pizzeria in privato, dare tempo per correggere, non scaricare dati altrui; pubblicare subito espone i dati dei clienti a chiunque.

4. XSS e CSRF

a) **XSS memorizzato**: colpisce tutti quelli che aprono la pagina delle recensioni. b) Codificare l'output: **"Ottima" & <i>veloce</i>**. c) Risorse e script **solo dal sito stesso**, niente script inline né da altri domini, nessun plugin (object). d) Un altro sito contiene un modulo nascosto verso `/cambia-email` che si invia da solo: il browser aggiunge il cookie e l'email diventa quella dell'attaccante, che poi fa "password dimenticata". Difese: **token anti-CSRF, cookie SameSite, richiedere la password attuale**.

5. Le password

a) 36^8 = **$2{,}82 \times 10^{12}$**. b) 282 s ≈ **4,7 minuti**. c) 282 × 600 000 = $1{,}69 \times 10^8$ s ≈ **5,4 anni**. d) Provare su un sito coppie email-password rubate da **altri siti**: funziona perché le persone riusano le password. e) Con il **k-anonimato** (Have I Been Pwned): si inviano solo i primi 5 caratteri dell'hash SHA-1 e si confronta in locale la lista che torna.

6. Il token

a) **401**: il token è scaduto, anche se la firma è valida. b) **Rifiutarlo (401)**: il server accetta solo l'algoritmo che ha deciso lui (HS256) e non si fida dell'`alg` scritto nel token. c) In una **variabile d'ambiente o un gestore di segreti**, generato casualmente: nel codice finirebbe su Git e chiunque potrebbe firmare token. d) `equals` si ferma al primo byte diverso e il tempo di risposta rivela quanti byte sono giusti (**attacco a tempo**); `isEqual` confronta in tempo costante.

7. E-mail

a) fornoblu.example **in osservazione** (p=none con report); consegne-veloci.example **scoperto** (niente SPF né DMARC). b) Leggere i report, attivare DKIM su tutti i servizi che inviano posta, poi **p=quarantine e infine p=reject**; non subito perché si rischia di bloccare le mail vere di servizi dimenticati. c) È un **dominio sosia**, diverso da quello protetto; aiutano formazione, controllo del mittente, filtri antispam e la registrazione preventiva dei domini simili.

8. Rete

a) `dns` → 2; `tcp.port == 443` → 3; `http.request.method == "POST"` → 1. b) Il **tempo di andata e ritorno** (RTT) verso il server. c) Vede IP, nome del sito (SNI), DNS, tempi e quantità; non vede pagine, ordine, indirizzo di consegna né password. d) **Non si può**: intercettare le comunicazioni dei clienti è reato (art. 617-quater c.p.) e violerebbe il GDPR; per le statistiche bastano i dati aggregati del router o del sito.

9. Forense

a) **RAM, disco, log remoto, backup**. b) Un dispositivo (o software) che **impedisce di scrivere sul disco originale** durante la copia. c) Il PC è stato **spento e riacceso** (o riavviato) in due minuti. d) Ogni fonte può essere sbagliata o alterata; se fonti indipendenti concordano, la ricostruzione è difficile da contestare.